

Risk ID	Asset/System	Threat	Likelihood(1-5)	Impact(1-5)	Risk Score	Current Control	Recommended Control	NIST Function
R001	Customer Database	SQL Injection	4	5	20	Basic input validaiton	Paramaterized Queries, Web Application Firewall	Protect
R002	Payment Processing System	UnAuthorized Acess	3	5	15	Password Authentication, MFA	Role Based Acess Control	Protect
R004	Employee Laptops	Malware/Ransomware	4	4	16	Basic antivirus	Endpoint Detection & Response, regular patching	Protect
R004	API Endpoints	DDoS Attack	3	4	12	Rate Limiting	Advanced DDoS mitigation ,load balancing	Protect
R005	Employee Email	Phishing/Social Engineering	5	3	15	Security awareness training	Email filtering ,MFA enforcement	Detect
R006	Cloud Storage	Misconfiguration	3	4	12	Basic access controls	Regular configuration audits, IaC (Infrastructure as Code)	Protect
R007	Backup Systems	Backup Failure	2	5	10	Manual backups	Automated backup with testing, offsite replication	Recover
R008	Network Infrastructure	Unauthorized Network Access	2	5	10	Firewall rules	Network segmentation, zero-trust architecture	Protect
R009	Third-party Vendors	Supply chain attack	2	5	10	Basic vendor agreements	Vendor security assessments, SLAs	Identify
R010	Incident Response	Slow Incident Detection	3	4	12	Manual monitoring	SIEM implementation, automated alerting	Detect
R011	Data In Transit	Data Interception	3	4	15	SSL/TLS encryption	End-to-end encryption, certificate pinning	Protect
R012	Admin Accounts	Privilege Escalation	2	5	10	Standard user privileges	Privileged Access Management (PAM), PIM	Protect
R013	Compliance Records	Non-compliance with Regulations	2	5	10	Manual documentation	Automated compliance tracking, audit logging	Govern
R014	Employee Offboarding	Access Not Revoked	3	4	12	Manual revocation process	Automated deprovisioning, access reviews	Govern
R015	Disaster Recovery	Extended Downtime	2	5	10	Basic recovery plan	Tested DRP, redundant systems	Recover